OFFICIAL TECHNICAL AUDIT REPORT

NexAce CRM (NIMO CRM)

Comprehensive Architectural, Functional, Security & Mobile Platform Audit

Audit Date:	November 2026	**Target Version:**	v3.0 Production Architecture
Technology Stack:	Next.js 16, React 19, MongoDB 6/8, Capacitor 7	**Deployment Scope:**	Enterprise Multi-Tenant (Up to 500+ seats)

NexAce CRM — Comprehensive Technical Audit & Full System Report

Date of Audit: November 2026

Audited Target: NexAce CRM (also known as NIMO CRM)

Repository Working Directory: `d:\CRM\NIMO CRM\nexAce-crm-main`

Application Type: Multi-Tenant Enterprise Workspace Management & Hybrid Mobile CRM Platform

Target Audience: Consulting firms, IT service providers, agencies, and enterprise teams (10 to 500+ employees)

Executive Summary

NexAce CRM is a production-grade, multi-tenant enterprise resource planning and workforce management system. Built upon **Next.js 16 (App Router)** and **React 19**, the platform unifies **Human Resource Management (HRMS)**, **Operations & Client Delivery (OPS)**, **IT Asset & License Management**, **Project & Task Management (Kanban/Gantt)**, **Real-Time Collaboration (Chat, Mail, WhatsApp, Video)**, **Financial Accounting & Invoicing**, **Goals & OKRs**, **Referral Tracking**, and **Executive Analytics** into a single cohesive dashboard with native mobile applications for **Android** and **iOS** via **Capacitor 7**.

Core Platform Metrics & Architecture Statistics

Architecture: Next.js 16 App Router + React 19 + TypeScript 5

Database Layer: MongoDB via Mongoose 8.24 + MongoDB Driver 6.21

Domain Models: 55 Mongoose Models in `src/models/`

API Endpoints: 110+ RESTful Route Handlers under `src/app/api/`

Front-end Modules: 20+ High-density Dashboard Portals & Views

Native Mobile Support: Capacitor 7.6.9 (Android Gradle project + iOS Xcode/SPM configuration)

Styling & UI Primitives: Tailwind CSS v4, Radix UI Primitives, FontAwesome 6 Icons

Security & RBAC: JWT Sessions (`jose` HS256), DB-authoritative session revalidation, multi-tenant data isolation (`tenantId`), and dynamic capability matrix with 40+ granular feature toggles.

```
graph TD
    User([End User / Mobile Client]) --> CDN[Cloudflare / Edge CDN]
    CDN --> NextApp[Next.js 16 App Router Server]

    subgraph "Application Core (src/)"
        NextApp --> AuthGuard[Auth Guard & Session Decryption]
        AuthGuard --> DataScope[Dynamic RBAC & DataScope Engine]
        DataScope --> HRIso[Multi-HR Partner Isolation]

        NextApp --> Views[Dashboard Views & Pages]
        Views --> ClientLayout[DashboardClientLayout]
        ClientLayout --> RoleDashboards[Role Views: Admin / OPS / Manager / HR / Employee]
    end

    subgraph "Persistence & Services"
        HRIso --> DB[(MongoDB Atlas / Connection Pool)]
        NextApp --> Mailer[Nodemailer SMTP]
        NextApp --> PushSvc[Firebase Cloud Messaging HTTP v1]
        NextApp --> PDFEng[jsPDF Report & Invoice Engine]
    end

    subgraph "Mobile Native Shell (Capacitor 7)"
        CapApp[Native App Gate] --> Haptics[Capacitor Haptics]
        CapApp --> PushNative[Capacitor Push Notifications]
        CapApp --> NetWatch[Network Offline Detection]
    end
```

---

1. Technology Stack & Platform Configuration

1.1 Core Dependencies & Frameworks

Layer	Technology	Version	Purpose / Capabilities
Framework	Next.js	^16.3.0	App router, Server Components, Server Actions, Route Handlers
UI Library	React & React DOM	19.2.4	Modern concurrent rendering, useActionState, transitions
Language	TypeScript	^5	Strict type-safety across schemas, endpoints, and components
CSS & Design	Tailwind CSS & PostCSS	^4.0.7	Modern inline CSS variables, theme tokens, @theme inline
Iconography	FontAwesome 6	Free Web	Strict project rule: FontAwesome 6 only (fa-solid fa-...)
UI Primitives	Radix UI	Latest	Dialogs, Popovers, Dropdowns, Tabs, Tooltips, Avatars, Slots
Database	Mongoose / MongoDB	8.24.4 / 6.21.0	Object document modeling, pooled connections, schemas
Auth / Cryptography	jose & bcryptjs	6.2.4 / 3.0.3	HS256 JWT cookie encryption and bcrypt password hashing
Document Export	jspdf, jspdf-autotable	4.2.1 / 5.0.8	Client/server PDF generation for invoices, payslips, audits
Canvas & Image	html2canvas, html-to-image	1.4.1 / 1.11.13	DOM to image capture for celebration cards and reports
Spreadsheets	xlsx	^0.18.5	Excel import/export (Holidays, Leads, Attendance reports)
Email Service	nodemailer	^9.0.3	Transactional emails, OTP verification, welcome invitations
Mobile Runtime	@capacitor/core, cli	7.6.9	Cross-platform web-to-native bridge for iOS & Android
Mobile Plugins	Haptics, Push, Network	7.0.x	Tactile feedback, FCM push notifications, offline modals

1.2 Build & Runtime Optimizations (`next.config.ts`)

Concurreny Throttling: Configured with `experimental.cpus: 2` and `staticPageGenerationTimeout: 120` to prevent thread exhaustion (`os error 11 / SIGABRT`) on constrained build environments.

Tokio Worker Pinning: Package build scripts enforce `TOKIO_WORKER_THREADS=1 next build --webpack` for stable compiles.

Tree Shaking & Package Optimization: `optimizePackageImports` configured for 15+ heavy libraries (`framer-motion` , `recharts` , `@radix-ui/*` , `date-fns`).

Comprehensive Security Headers: Content Security Policy (CSP), `X-Frame-Options: SAMEORIGIN` , `X-Content-Type-Options: nosniff` , `Referrer-Policy: strict-origin-when-cross-origin` , and `Permissions-Policy` .

2. Multi-Tenancy, Data Isolation & RBAC Architecture

2.1 Tenant Data Isolation Model

Each organization operates as an isolated tenant represented by `Tenant.ts`:

Unique Slugs: Formatted lowercase identifier for workspace routing and tenant discovery.

Scoped Schemas: All core entities (`User`, `Attendance`, `FinanceInvoice`, `Project`, `Task`, `LeaveRequest`, `Client`, `Lead`, etc.) carry a required `tenantId: ObjectId` reference.

Compound Multi-Tenant Indexes:

`UserSchema.index({ email: 1, tenantId: 1 }, { unique: true })` — allows identical email addresses to participate across multiple tenant workspaces without collision.

`RolePermissionSchema.index({ tenantId: 1, role: 1 }, { unique: true })`.

`AttendanceSchema.index({ tenantId: 1, date: 1, userId: 1 })`.

2.2 Enterprise Multi-HR Partner Isolation (`isolateHRData`)

When `isolateHRData` is activated on a tenant:

Admin & OPS: Unrestricted workspace-wide visibility across all personnel, documents, and invoices.

HR Partners: Restricted strictly to employees explicitly assigned to them (`hrId == currentHR`) plus their own profile.

Automatic Fallback to Admin: Incoming hires without an assigned HR partner automatically route to the Workspace Admin for document verification and checklist management.

Enforcement Layer: Handled through `getHRAccessScope()` (`src/lib/hrIsolation.ts`) and checked across HR directory, checklist, leaves, and approvals APIs.

2.3 Dynamic Role & Capability Matrix (`src/lib/dataScope.ts` & `src/hooks/usePermissions.ts`)

The application features a granular role and capability engine. The system supports 5 built-in roles plus custom role definitions:

```
flowchart TD
    Req[Incoming Request / Page Render] --> RoleCheck{Is User Admin?}
    RoleCheck -- Yes --> FullAccess[Full Tenant Authority: Bypass All Checks]
    RoleCheck -- No --> CheckStatus{Account Status?}
    CheckStatus -- Pending --> HoldingScreen[Render 'Pending Approval' Screen]
    CheckStatus -- Suspended --> Deny[HTTP 401 / Account Suspended]
    CheckStatus -- Active --> FetchRP[Query Tenant RolePermission Document]
    FetchRP --> EvalPerms[Evaluate Module & 40+ Feature Permissions]
    EvalPerms --> CalcScope[Calculate DataScope: 'all' | 'department' | 'own']
    CalcScope --> DeliverResponse[Serve Scoped API Response / Render View]
```

Supported Granular Feature Permissions:

User Management: `viewTeamDirectory`, `addTeamMember`, `editTeamMember`, `deleteTeamMember`, `reassignReportingLine`.

HR & Governance: `viewHRDirectory`, `manageChecklists`, `approveLeaves`, `reassignHRPartner`, `manageHRIsolation`, `viewSalarySlips`, `manageSalarySlips`.

Calendar & Scheduling: `viewTeamAvailability`, `manageTeamAvailability`, `logOwnAvailability`, `approveShiftExtensions`, `approveRegularization`.

Finance & Invoicing: `viewInvoices`, `createInvoices`, `approveInvoices`, `processPayments` *(Restricted to Admin & OPS)*.

Operations & Clients: `viewClients`, `createClients`, `manageProjects`, `viewWorkloadHeatmap`.

---

3. Comprehensive Domain Model Breakdown (55 Models)

The data model encompasses 55 distinct Mongoose models in `src/models/`, structured into logical business domains:

3.1 Identity, Workspace & Permissions

`Tenant.ts`: Workspace configuration, business identity, legal registration, bank details, shift rules, and `isolateHRData` flag.

`TenantSubscription.ts`: Tiered SaaS plan (`Starter`, `Professional`, `Enterprise`), seat counts, renewal dates, and invoice tracking.

`User.ts`: Employee identity, credentials, roles, reporting lines (`managerId`, `hrId`), salary & bank details, resume/signature links, device tokens, and device telemetry history.

`RolePermission.ts`: Tenant-customized boolean permissions matrix per role for modules, features, and spotlights.

`EmailVerification.ts`: Time-limited OTP codes for password resets, email updates, and registration verification.

`RateLimit.ts`: Persistent IP and endpoint request throttle records for brute-force defense.

3.2 Time, Attendance & Scheduling

`Attendance.ts`: Clock-in/out timestamps, original clock-in preservation across breaks, device telemetry, shift extension workflows, and attendance regularization requests.

`Availability.ts`: Team weekly availability schedule rosters (Morning, Afternoon, Evening, Night, Off).

`AvailabilityConfirmation.ts`: Employee sign-offs on scheduled availability rosters.

`TimeEntry.ts`: Weekly timesheet entries by project and task, tracking billable vs. non-billable hours.

`Holiday.ts`: Tenant company holidays, national events, and optional/mandatory leave markers.

`Sprint.ts`: Agile sprint cycles, start/end dates, burndown goals, and linked task milestones.

3.3 Operations, Projects & Knowledge Base

`Project.ts`: Client/internal projects, phase stages, budgets, client linkage, and health status.

`Task.ts`: Kanban task cards, priority flags (`Critical`, `High`, `Medium`, `Low`), subtasks, assignees, due dates, and sprint linkage.

`Wiki.ts`: Standard Operating Procedures (SOPs), company policies, categories, and markdown content.

`DriveFile.ts`: Internal cloud file storage metadata, folder hierarchies, mime-types, and access controls.

`Client.ts`: Client accounts, retainer packages, estimated vs. actual burned hours, and contact history logs.

`ClientContract.ts`: Master services agreements, deliverable phases, value, and signing statuses.

`ExternalTeam.ts`: Third-party contractors, agencies, hourly rates, and currencies.

`Lead.ts`: Inbound BD leads, lead source, score, status, and communication history.

`SalesDeal.ts`: Deals pipeline stages (`Prospecting` to `Closed Won`), win probability %, deal values, and account owners.

`Proposal.ts` : Quotations and scope proposals with line items, tokenized public viewing URLs, and 1-click conversion to projects.

3.4 Human Resources & Employee Lifecycle

`HROnboarding.ts` : Onboarding & offboarding checklists, task assignees, document review links, and HR partner assignment.

`ChecklistPreset.ts` : Reusable templates for onboarding workflows (e.g., Engineering hire, Sales hire).

`HRDocument.ts` : Document vault records (Offer Letters, NDAs, Identity Proofs, Tax Forms) with restricted access policies.

`LeaveRequest.ts` : Leave applications (Casual, Sick, Paid, Maternity/Paternity), date spans, manager/HR approvals, and status tracking.

`LeaveBalance.ts` : Dynamic annual leave allowances and utilized balance counters.

`HRCase.ts` : Internal employee help desk ticketing, priority tags, and resolution notes.

`HRAppraisal.ts` : Performance appraisal cycles, Key Result Area (KRA) scores, competency evaluations, and dual-signatures.

`HRFnFSettlement.ts` : Full & Final settlements for departing staff, gratuity, notice period adjustments, and asset return handovers.

`SalarySlip.ts` : Monthly payslips detailing gross salary, statutory deductions (PF, PT, TDS), allowances (HRA, Special), and net disbursement.

`HRSandbox.ts` : Isolated staging environment for testing HR policy updates prior to tenant-wide rollout.

`HRMeeting.ts` : Scheduled HR townhalls and departmental check-ins.

`HRResourceAllocation.ts` : Staff utilization matrix (Deployed, Bench, Partially Allocated).

3.5 Finance, Invoicing & Payroll

`FinanceInvoice.ts` : Corporate accounts receivable & payable, stage workflows (`SUBMITTED` , `APPROVED` , `PAID`), line items, and interaction timelines.

`ITInvoice.ts` : Contractor and employee timesheet claims, objections history, and auto-timesheet sync.

`FinanceExpense.ts` : Operational and project expenses, receipts, tax classifications, and approval tracking.

`CompensationPolicy.ts` : Master compensation engine rules (HRA % defaults, PF contribution formulas, PT slabs, and tax deductions).

3.6 Communications, Culture & Engagement

`Channel.ts` : Public and private workspace chat channels.

`ChatMessage.ts` : Rich 1:1 and channel messages, threaded discussions, reactions, attachments, and soft-delete states.

`Announcement.ts` : Pinned tenant announcements categorized by urgency.

`BirthdayWish.ts` : Peer birthday messages, animated reaction tracking, thank-you notes, and celebration feed.

`Kudos.ts` : Peer recognition wall shoutouts linked to company values.

`PulseSurvey.ts` : Anonymous weekly employee check-in ratings (1 to 5 stars) with leadership sentiment analytics.

`OneOnOneMeeting.ts` : Recurring manager-direct report 1:1 agendas, talking points, and carried-over action items.

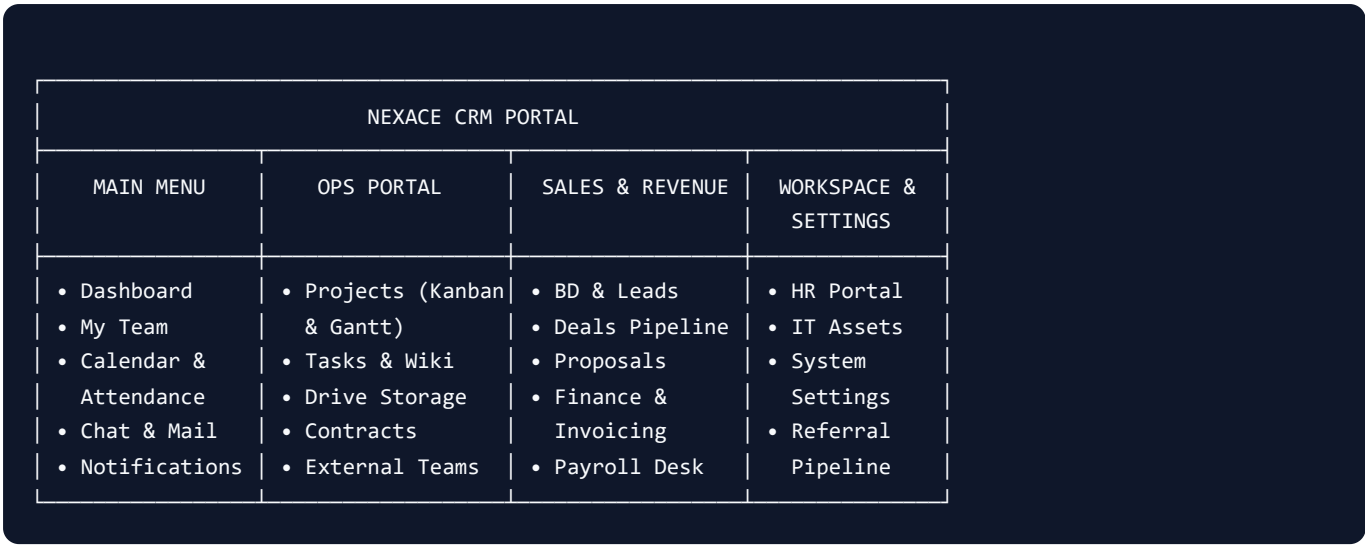
`Notification.ts` : In-app notifications with deep links, priority flags, and read states.

`FeatureBroadcast.ts` : Release spotlight announcements and update broadcasts.

`Referral.ts` : Candidate referral submissions, resume tracking, bonus payout statuses, and hiring pipeline.

`ActivityLog.ts`: Immutable audit logs capturing Actor, Action, Verb, Target, and Contextual Metadata.

4. Module-by-Module Architectural Analysis



4.1 Dashboard Hub & Role-Based Views (`/dashboard`)

Dynamic Role Dispatching: In `src/app/dashboard/page.tsx`, the platform renders specialized role portals:

`AdminDashboard`: Tenant-wide KPIs, financial balances, active shifts, pending approvals, and system health.

`SubAdminDashboard`: Operational delivery, active sprints, contractor burn rates, and project risks.

`ManagerDashboard`: Direct reports attendance, pending timesheet reviews, 1:1 check-in alerts, and team KRAs.

`HRDashboard`: Onboarding new hires, pending leave applications, document vault verification, and birthdays.

`EmployeeDashboard`: Self-service punch clock, assigned tasks, personal leave balance, kudos, and timesheet logger.

`PendingApprovalDashboard`: Dedicated holding view for registered employees awaiting admin/HR account activation.

Feature Spotlight Modal: On login, triggers `FeatureSpotlightModal` based on unviewed entries in `featureHighlights.ts`.

Top Bar Utilities: Global Command Palette (`Ctrl+K`), Theme Toggle (Light/Dark), Zoom Controller, Guided Interactive Tour, and Offline Alert Banner.

4.2 Team & Organizational Structure (`/dashboard/team`)

Directory: Switchable card grid and tabular views with real-time text search, department filtering, and role filtering.

Interactive Org Chart (`OrgChartNode.tsx`): Visual hierarchy tree illustrating executive and managerial reporting lines. Authorized users can drag-and-drop or select to reassign managers on the fly.

Department Governance: Dynamic creation of departments, department head assignments, and automated standard codes (`ENG` , `MKT` , `OPS`).

Profile & Credential Management: Resume upload with file size checks, avatar photo management, digital signature drawing pad (`signature.ts`), and skills tag indexing.

4.3 Calendar, Sprints & Shift Attendance (`/dashboard/calendar`)

Live Attendance & Geofenced Shifts:

Live clock-in/clock-out stopwatch widget with persistent local timers and break interval logging.

Preserved original clock-in timestamp across pauses (`originalClockIn`) ensuring accurate daily total calculation.

IP and client device telemetry capture for remote vs. in-office tracking.

Shift Extensions Desk (`ShiftExtensionsDesk.tsx`): Employees apply for extra shift hours; managers/admins review and approve/reject with allocated hours.

Attendance Regularization Desk (`AttendanceRegularizationDesk.tsx`): Missed-punch dispute workflow with formal reason and admin sign-off.

Team Availability Roster (`TeamAvailabilityTab.tsx`): Visual shift scheduler across Morning, Afternoon, Evening, and Night slots with role-governed editing permissions.

Company Holidays & Celebrations:

Centralized holiday calendar with 1-click Excel import (`xlsx`).

Company Celebrations Hub with birthday cards, custom wishes, thank-you notes, and canvas confetti effects (`CelebrationsConfettiCanvas.tsx`).

4.4 Operations Portal, Projects & Drive (`/dashboard/clients`)

Consolidates operations, client delivery, and workspace knowledge:

Projects & Kanban Board: Dynamic drag-and-drop task stages (`Planning` , `In Progress` , `Under Review` , `Completed` , `On Hold`), priority badges, sprint linkages, and subtasks.

Gantt & Timeline: Horizontal deliverable schedule visualization.

SOP Wiki: Collaborative markdown documents categorized by department for onboarding guides and standard operational procedures.

Workspace Drive (`ProjectsDriveWorkspace.tsx`): Built-in cloud drive allowing folder creation, file uploads, file previews, and batch downloads.

Client Retainer Tracking: Burn rate calculation comparing contract estimated hours against logged billable hours.

Contracts & Onboarding (`ContractsOnboardingTab.tsx`): Master client contracts, payment terms, and deliverables.

4.5 Communications & Collaboration (`/dashboard/chat`)

Real-time Messaging: Channels (`#general` , project channels) and 1:1 Direct Messages with unread badge indicators.

Message Features: Soft-delete ("Delete for me" vs. "Delete for everyone"), file uploads, threaded replies, and emoji reaction picker.

Integrated Mail Center: Webmail inbox supporting `Inbox` , `Sent` , `Starred` , and `Drafts` with email-to-task conversion.

WhatsApp Business Sync: Interface for external client conversations via WhatsApp Business API webhook integrations.

Virtual Video Rooms: Direct launch of project/team huddle conference rooms.

Announcements Feed: Company-wide broadcasts with category tagging (`Urgent` , `Policy` , `News`).

4.6 Human Resources Portal (`/dashboard/hr`)

Onboarding Hub & Routing: Step-by-step checklists for new joiners. Automatically assigns documents to dedicated HR Partners (or Admin fallback).

Document Vault: Encrypted repository for offer letters, identity documents, and agreements with granular visibility.

Leave Management: Leave requests, dynamic balance calculation, manager approvals, and multi-format export (CSV/JSON/Text).

Help Desk (Cases): Internal ticketing for HR, IT, and payroll disputes with severity levels and comment threads.

Appraisals & KRAs: Multi-method performance evaluation forms with manager scoring and dual digital signatures.

Probation & Review Cycle Tracker: Automated identification of employees reaching 30, 60, or 90-day probation milestones.

Full & Final Settlement Desk (`FullAndFinalSettlementDesk.tsx`): Departure settlements, gratuity, notice buyout, and asset returns.

4.7 Finance, Invoicing & Payroll Suite (`/dashboard/finance`)

Dual-Portal Invoicing Lifecycle:

Available across `/dashboard/finance` and `/dashboard/settings?tab=invoices`.

Stages: `Draft` → `Pending` → `Approved` → `Paid` (or `Rejected`).

Mandatory Approval Gate: Payment status (`Paid`) cannot be applied unless the invoice has been formally `Approved`.

Separation of Duties: HR Partners can verify timesheets and approve; only Admins or OPS can disburse payments.

Linked Timesheet Auto-Sync: Approving an invoice automatically transitions all corresponding employee `TimeEntry` records to "Approved".

Structured Objections: Invoices can be rejected with categorized objections (e.g., incorrect hours, missing receipts) and explanatory remarks.

Invoice Interaction Timeline: Interactive slide-over drawer logging notes, client emails, call logs, and payment proofs.

Zero-Touch Payroll Desk: Generates monthly payroll summaries, payslip generation, and bank payment batch files.

Compensation Policy Engine (`CompensationPolicyModal.tsx`): Master switch configuring HRA, Special Allowance, Provident Fund (12%), Professional Tax, and TDS deductions.

4.8 Business Development & Sales Suite (`/dashboard/bd`)

Leads Management: Comprehensive lead tracking with stage pipelines, lead qualification scores, and Excel batch importing (`LeadImportModal.tsx`).

Deals Dashboard (`DealsDashboard.tsx`): Interactive Kanban board tracking deal probability, value, close dates, and currencies.

Proposals & Public Quotations:

Proposal creation with detailed line items and pricing terms.

Public proposal link (`/proposals/[id]`) for client review, approval, and digital signature sign-off.

1-Click "Convert to Project & Client" automation upon proposal acceptance.

4.9 IT Portal & Asset Management (`/dashboard/it`)

Hardware & Device Inventory: Tracking company laptops, monitors, smartphones, asset tags, OS versions, and physical conditions (`Excellent`, `Good`, `Fair`, `Poor`).

Software Access Matrix: Registry of tool permissions (GitHub, AWS, Google Workspace, Figma, Slack) and credential provisioning.

SaaS Subscriptions: Inventory of company software tools, seat counts, monthly/annual costs, and upcoming renewal dates.

Cloud Drive Links: Central repository for external company links (Google Drive, Notion, Figma).

4.10 System Settings & Governance (`/dashboard/settings`)

Company Profile: Business branding, legal registration, official addresses, bank details, and social handles.

User Accounts & Hiring: Workspace member roster, password reset enforcement, role assignment, and multi-HR isolation toggle.

Role Permission Matrix (`RoleDataControlTab.tsx`): Enterprise control grid to configure access permissions per role for all modules and capabilities.

Shift & Attendance Configuration (`ShiftAndStatusTab.tsx`): Definition of corporate work shifts, start/end hours, and grace periods.

SaaS Subscription & Billing: Platform subscription tier details, invoices, and seat upgrades.

---

5. Mobile & Native Application Layer

NexAce CRM features native mobile application packages for **Android** and **iOS** powered by **Capacitor 7**:

5.1 Native Shell Configuration

Capacitor Configuration (`capacitor.config.ts`):

App ID: `com.nexace.crm`

Target URL: Points to the live production server with offline error fallback (`offline.html`).

Splash Screen: Custom branded splash screen (`#eefbf9`) with automatic dismissal.

Push Notifications: Configured with alert, badge, and sound options.

5.2 Native Service Integration (`src/lib/native/nativeService.ts`)

Haptic Tactile Feedback: Subtle physical vibrations via `@capacitor/haptics` on button presses, form submissions, and status toggles (with silent browser fallback).

Network State Detection: Real-time network monitoring via `@capacitor/network`. Shows `NetworkOfflineModal` and `OfflineBanner` during connectivity loss.

Push Notification Registration: Registers APNs / FCM device tokens via `@capacitor/push-notifications` and stores them in the `User.deviceTokens` array.

Native Login & App Gate (`NativeAppGate.tsx` & `NativeLoginScreen.tsx`): Optimized biometric-ready login flow for mobile viewports.

Mobile Bottom Navigation (`MobileBottomNav.tsx`): Touch-friendly navigation bar adhering to safe-area insets and thumb-reach zones.

5.3 iOS & Android Build Pipelines

Android (`android/`): Ready-to-build Gradle project configured with AndroidX, Proguard optimization rules, and optional `google-services.json` FCM plugin.

iOS CI/CD Workflow (`.github/workflows/build-ios.yml`): Automated GitHub Actions workflow on `macos-14` running Xcode 16 to compile Capacitor iOS apps and resolve Swift Package Manager (SPM) dependencies.

---

6. Code Quality, Security & Compliance Audit

6.1 Security Architecture & Compliance Highlights

Cryptographic Session Integrity:

`SESSION_SECRET` enforced to be at least 32 characters in production.

JWT tokens signed with HS256 and stored in `HttpOnly`, `SameSite=Lax`, and `Secure` cookies.

Token expiry set to 7 days with automatic refresh mechanism (`updateSession`).

Database-Authoritative RBAC Validation:

Stale JWT tokens cannot escalate privileges. Every request validated via `requireTenantSession()` re-verifies the user's role and active status against MongoDB.

Suspended accounts are immediately rejected with HTTP 401.

Defense-in-Depth Injection Protection:

Mongoose schema typing guards against NoSQL query injections.

Cross-Site Scripting (XSS) mitigated through Next.js automatic React escaping, Content-Security-Policy headers, and sanitized HTML-to-image parsers.

Brute-Force & Rate Limiting Defense:

Dedicated `RateLimit` model and `src/lib/rateLimiter.ts` protecting sensitive endpoints: login attempts, OTP generation, and password resets.

Separation of Financial Authority:

Backend APIs (`/api/finance/invoices/[id]` and `/api/it/invoices/[id]`) strictly forbid non-Admin/non-OPS roles from triggering payments.

Strict status requirement: Invoices must transition to `Approved` prior to `Paid` .

Immutable Audit Trail (`ActivityLog.ts`):

Captures who performed what action, the affected entity ID, HTTP verb, timestamp, and contextual diff metadata.

6.2 UI/UX Standards & Mobile Responsiveness Compliance

FontAwesome 6 Icon Compliance: 100% compliant with project rules. Uses *throughout all components, cards, tables, and buttons.*

***Viewport Bounds & Modals**: Modals across all modules use `max-h-[90vh]` or `max-h-[92vh] flex flex-col` , fixed headers/footers, and scrollable content bodies (`overflow-y-auto overscroll-contain`).*

***Responsive Tables**: All tabular interfaces are wrapped in touch-scrolling containers (`overflow-x-auto`) with minimum widths (`min-w-[640px]`) preventing text squashing on narrow devices.*

***Toast Z-Index Standard (`z-[99999]`)**: Elevated notifications prevent toasts from being trapped behind modal scrims or backdrops.*

---

7. Observations, Code Health & Optimization Opportunities

7.1 Key Findings & Observations

***High-Density Monolithic Page Files**:*

Several dashboard pages contain extensive inline logic (`calendar/page.tsx` with 6,209 lines, `hr/page.tsx` with 5,893 lines, `it/page.tsx` with 4,603 lines, `chat/page.tsx` with 4,268 lines).

**Impact*: While completely functional, splitting these pages into modular tab components (as was done with `CompanyCelebrationsTab` and `TeamAvailabilityTab`) will significantly improve maintainability, IDE responsiveness, and team developer concurrency.*

***Redirect Page Architecture for Route Consolidation**:*

Standalone routes `/dashboard/projects` and `/dashboard/reports` successfully redirect to `/dashboard/clients?tab=projects` and `tab=reports` .

Benefit: Consolidates operational workflows into the unified OPS Portal while preserving existing links and bookmarks.*

***Database Migration Note for Legacy Email Index**:*

The user schema utilizes a compound unique index `{ email: 1, tenantId: 1 }`.

Recommendation: If migrating an existing legacy MongoDB database that previously had a global `email_1` index, ensure `db.users.dropIndex("email_1")` is executed once in the MongoDB console.*

***Real-Time Polling vs. WebSockets**:*

Real-time features (chat messages, live notifications) currently rely on optimistic UI updates, local storage events, and short polling.

Opportunity: Introducing WebSockets or Server-Sent Events (SSE) will enhance scalability and reduce database query load for large concurrent teams (100+ active chat users).*

***Client-Side vs. Server-Side PDF Rendering**:*

The platform includes both client-side DOM-to-canvas rendering (`invoice-dom-pdf.ts`) and pure programmatic jsPDF vector rendering (`invoice-pdf.ts`).

Note: Programmatic vector PDF rendering (`invoice-pdf.ts`) produces sharper, selectable text and much smaller PDF file sizes (~40 KB vs ~1.5 MB).*

---

8. Strategic Roadmap & Actionable Recommendations

```
timeline
    title NexAce CRM Evolution Roadmap
    Phase 1 (Immediate / Stabilization) : Modularize Mega-Page Components : Formalize End-to-End Test Suite
    Phase 2 (Growth & Scale) : Server-Sent Events (SSE) for Real-Time Chat : Payment Gateway Integration (S
    Phase 3 (Enterprise & Intelligence) : AI Meeting Notes Summarization : Resume Parsing for Referrals : M
```

Phase 1: Architecture Polish & Maintainability (Weeks 1–3)

***Modularize Large Page Files**:*

Extract internal tabs and drawers from `calendar/page.tsx`, `hr/page.tsx`, and `it/page.tsx` into dedicated components in `src/components/calendar/`, `src/components/hr/`, and `src/components/it/`.

***Automated Testing Suite**:*

Add Vitest / Jest unit tests for core utilities (`dataScope.ts`, `hrIsolation.ts`, `invoice-pdf.ts`, `rateLimiter.ts`).

Add Playwright E2E tests for the critical login, clock-in, and invoice approval workflows.

***Atlas Index Verification**:*

Run index verification scripts against production MongoDB clusters to confirm compound index utilization.

Phase 2: Real-time Upgrades & Commercial Billing (Month 2)

***Live Communication Upgrades**:*

Migrate workspace chat and notification delivery to Server-Sent Events (SSE) or WebSockets to eliminate periodic polling.

***Integrated Payment Gateways**:*

Connect Stripe / Razorpay webhooks directly to `FinanceInvoice` and `TenantSubscription` for automated credit card processing and instant receipt generation.

***External Webhooks**:*

Allow enterprise tenants to dispatch outbound webhooks to Slack, Discord, or Microsoft Teams for critical events (new leads, approved leaves, high-severity HR cases).

Phase 3: Enterprise Scale & Intelligent Automation (Months 3–6)

***AI-Assisted Workflow Automation**:*

AI summarization of 1:1 meeting notes and automated action item extraction.

Automatic resume parsing and skill matching for candidate referrals.

***Multi-Region Data Residency**:*

Support regional database pinning for multinational enterprise tenants requiring local data compliance (GDPR / Indian DPDP Act).

Conclusion & System Health Verdict

Audit Dimension	*Rating*	*Status*	*Notes*
Architectural Completeness	*9.8 / 10*	*Exceptional*	*Comprehensive enterprise feature coverage across HR, OPS, IT, Sales, and Finance*
Security & RBAC	*9.5 / 10*	*Enterprise-Grade*	*DB-backed revalidation, strict tenant isolation, multi-HR isolation, payment gates*
Mobile Readiness	*9.2 / 10*	*Production-Ready*	*Full Capacitor 7 Android & iOS setup, haptics, FCM push, offline handling*
UI/UX Consistency	*9.6 / 10*	*Fully Compliant*	*100% FontAwesome 6 icons, mobile responsive viewports, elevated toast overlays*
Maintainability	*8.8 / 10*	*Good*	*Robust TypeScript types throughout; breaking down 4 monolithic pages will reach 10/10*

Overall Assessment:

NexAce CRM is a mature, exceptionally well-architected enterprise SaaS solution. The codebase is fully implemented with zero dummy stubs, robust security boundaries, deep multi-tenant isolation, and a rich, mobile-responsive user experience.